Semana 05 — Vulnerabilidades web según OWASP Top 10

Fase 2: Ofensiva controlada — instrucciones paso a paso

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	05 de 10
Fase	2 — Ofensiva controlada
Modalidad	4 grupos, trabajo desde sus propios equipos
Dedicación	4 horas de laboratorio + 2 horas de estudio independiente
Instrumento	Control de fase 2
Entrega	GitHub, carpeta semana_05/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Antes de la sesión

Estas tareas se hacen en casa, antes de la práctica. Si el repositorio o el laboratorio no están listos al empezar, la sesión se va en arreglarlos y no alcanza para el informe.

1. Comprobar que el repositorio del grupo tiene la carpeta semana_05 creada.
2. Revisar la retroalimentación del docente sobre la semana anterior y corregir lo pendiente.
3. Traer instaladas las herramientas de la semana: DVWA, Juice Shop, Navegador con herramientas de desarrollo.
4. Confirmar que el laboratorio arranca y que los tres servicios responden antes de la sesión.
5. Leer el objetivo y los contenidos para llegar con el vocabulario de la práctica.

2 Objetivo de la semana

Explotar de forma controlada inyección SQL, XSS y LFI, y explicar la causa raíz y el control que lo evita.

3 Contenidos que se aplican

- OWASP Top 10 2021 y categorías con mayor impacto.
- Control de acceso roto y exposición de datos sensibles.
- Inyección SQL, XSS reflejado y almacenado, LFI y RFI.
- Configuración insegura y componentes desactualizados.
- Evidencia reproducible, capturas y causa raíz en el código.

4 Escenario

Cada grupo explota tres vulnerabilidades en DVWA y resuelve tres retos de Juice Shop, documentando payload, evidencia, causa raíz y mitigación.

5 Paso a paso de la práctica

1. Ejecutar un XSS reflejado en DVWA y capturar la evidencia del reflejo.
2. Ejecutar una inyección SQL que devuelva datos no previstos y documentar el payload.
3. Explotar un LFI para leer un archivo del sistema del contenedor.
4. Resolver tres retos de Juice Shop y anotar la pista y el razonamiento.
5. Para cada caso, identificar la línea de código o configuración responsable y el control que lo evita.

Concepto clave

Regla de oro de la evidencia: guarda la salida de cada paso en `semana_05/evidencia/` en el momento en que la obtienes. Reconstruirla después no es evidencia, es memoria.

Herramientas de la semana: DVWA, Juice Shop, Navegador con herramientas de desarrollo.

6 Rol de cada grupo esta semana

Todos los grupos resuelven la misma práctica, cada uno en su propio repositorio y su propio laboratorio: el trabajo de un grupo no depende del de otro. El rol cambia el énfasis del trabajo y lo que cada grupo aporta al comparar resultados en clase, al final.

Grupo	Rol	Aporte principal
Grupo 1	**Azul**	La mitigación aplicada, el comando de verificación y la comparación de resultados.
Grupo 2	**Púrpura**	La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.
Grupo 3	**Legal y reporte**	La versión final del informe y la declaración explícita de lo que no se pudo verificar.
Grupo 4	**Rojo**	Evidencia cruda en semana_05/evidencia y el apartado de reproducción del informe.

7 Qué se entrega

Informe técnico con payloads, evidencia anonimizada, causa raíz y mitigación por hallazgo.

Estructura de la carpeta `semana_05/`:

- README.md con integrantes, roles y tabla de semanas entregadas.
- semana_05/informe.md o informe.pdf con el entregable de esa práctica.
- semana_05/scripts/ con el código, con type hints y docstrings.
- semana_05/evidencia/ con salidas, capturas y hashes anonimizados.
- semana_05/README.md con el resumen de lo hecho y lo que no se pudo verificar.

Reglas que se verifican al corregir:

- Nada de secretos, tokens ni contraseñas en el repositorio; las claves van en .env ignorado.
- Nada de imágenes de disco, muestras de malware ni binarios: solo hashes y enlaces.
- Evidencia anonimizada: sin datos personales de terceros ni credenciales reales.
- Un commit por entrega con mensaje "semana NN: <entregable>".
- La práctica cuenta como entregada solo si está en el repositorio antes del corte.

8 Cómo se corrige

Criterio	Peso
Explotación reproducible de los tres tipos de vulnerabilidad	3,0
Causa raíz correctamente identificada	2,5
Mitigación concreta y verificable por hallazgo	2,0
Evidencia clara y anonimizada	1,5
Retos de Juice Shop justificados	1,0
Total	**10,0**

9 Lista de verificación antes del corte

- El repositorio del grupo existe, es privado y el docente aparece como colaborador.
- La carpeta semana_05/ está en el repositorio, no solo en el equipo.
- El informe explica qué se hizo, con qué comandos y qué se obtuvo.
- La evidencia está anonimizada: sin datos personales, credenciales ni secretos.
- Cada hallazgo tiene su hash o su salida cruda que permite reproducirlo.
- El commit ’semana 05: <entregable>’ está hecho antes del corte.

Alcance y autorización: solo se trabaja sobre los contenedores del laboratorio o sobre sistemas con autorización escrita. Si el objetivo no está en ese conjunto, se detiene la práctica y se consulta al docente. El uso de estas técnicas fuera del alcance tiene consecuencias académicas y legales.

Recuerda

Dudas de la semana: se responden en clase o en el repositorio. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

10 Glosario de la semana

Término	Definición
OWASP Top 10	Lista de las categorías de riesgo web con mayor impacto, revisada periódicamente. Es un punto de partida, no un catálogo exhaustivo.
Control de acceso roto	Fallo que permite ver o modificar recursos de otro usuario cambiando un identificador o una petición (IDOR, BOLA).
Inyección SQL	Introducir sintaxis SQL en una entrada no parametrizada para alterar la consulta. Se evita parametrizando y validando.
XSS	Inyectar script que se ejecuta en el navegador de otra persona. Puede ser reflejado, almacenado o en el DOM según dónde persista.
LFI	Inclusión local de ficheros que permite leer archivos del servidor a través de una ruta manipulada.
Causa raíz	Defecto concreto que permite la vulnerabilidad, como una consulta concatenada o una salida sin codificar. Es distinto del síntoma observado.